

Vulnerability Assessment Report

Future Interns – Cyber Security Task 1 (2026)

Prepared By

Gokul R
B.Tech AIML
SNS College of Technology

Assessment Type

Passive Vulnerability Assessment (Read-Only Scope)

Target Website

<http://demo.testfire.net>

Date of Assessment

09 May 2026

Tools Used

- OWASP ZAP (Passive Scan)
 - Browser Developer Tools
 - Nmap (Basic Exposure Analysis)
-

1. Executive Summary

This security assessment was conducted on the public website <http://demo.testfire.net> using ethical and passive testing techniques. The purpose of this assessment was to identify common security weaknesses without exploiting or damaging the target website.

The assessment focused mainly on:

- HTTP security headers
- Cookie security settings
- Information disclosure
- Session management configuration
- Basic web application security misconfigurations

During the analysis, several medium and low-risk vulnerabilities were identified. These vulnerabilities do not immediately compromise the website but may increase the risk of attacks such as Cross-Site Scripting (XSS), clickjacking, session hijacking, and information disclosure if left unresolved.

No active exploitation or harmful testing was performed during this assessment.

2. Scope of Testing

In Scope

- Public-facing web pages
- Passive vulnerability scanning
- Header analysis
- Cookie analysis
- Security configuration review

Out of Scope

- Brute-force attacks
 - Denial-of-Service (DoS)
 - Exploitation attempts
 - Authentication bypass
 - Malware testing
 - Data extraction
-

3. Methodology

The following methodology was used during the assessment:

1. The target website was added into OWASP ZAP.
 2. Passive scanning was performed.
 3. HTTP response headers were analyzed.
 4. Session cookies and browser behavior were inspected.
 5. Security weaknesses were documented.
 6. Risks were classified into:
 - Low
 - Medium
 - Informational
 7. Recommendations were prepared based on industry best practices.
-

4. Vulnerability Findings

Finding 1 – Content Security Policy (CSP) Header Not Set

Risk Level

Medium

Description

The website does not implement a Content Security Policy (CSP) header.

A CSP header helps browsers decide which content sources are trusted. Without CSP protection, attackers may inject malicious scripts into the website through Cross-Site Scripting (XSS) attacks.

Evidence

OWASP ZAP identified:

- “Content Security Policy (CSP) Header Not Set”

Impact

If an attacker successfully injects malicious JavaScript into the application, the browser may execute it because there is no CSP restriction.

Possible impacts include:

- Session theft
- Data theft
- Malicious redirects
- Browser-based attacks

Recommendation

Configure a proper Content Security Policy header.

Example:

```
Content-Security-Policy: default-src 'self';
```

The policy should allow only trusted resources.

Finding 2 – Missing Anti-clickjacking Header

Risk Level

Medium

Description

The application does not include anti-clickjacking protection headers such as:

- `X-Frame-Options`
OR
- `Content-Security-Policy frame-ancestors`

This allows attackers to load the website inside malicious invisible frames.

Evidence

OWASP ZAP identified:

- “Missing Anti-clickjacking Header”

Impact

Attackers may trick users into clicking hidden buttons or performing unintended actions.

Possible risks include:

- Unauthorized actions
- Fake login overlays
- User interaction hijacking

Recommendation

Add one of the following headers:

X-Frame-Options: DENY

OR

Content-Security-Policy: frame-ancestors 'none';

Finding 3 – Cookie without SameSite Attribute

Risk Level

Low

Description

The session cookie (`JSESSIONID`) is set without the `SameSite` attribute.

Cookies without SameSite protection may be sent during cross-site requests, increasing the possibility of Cross-Site Request Forgery (CSRF) attacks.

Evidence

Observed Cookie:

Set-Cookie: JSESSIONID=...

The cookie does not include:

SameSite=Lax

or

SameSite=Strict

Impact

Attackers may attempt to abuse authenticated sessions through malicious external websites.

Recommendation

Add a SameSite attribute to session cookies.

Recommended:

Set-Cookie: JSESSIONID=xyz; SameSite=Lax; Secure; HttpOnly

Finding 4 – Server Version Information Disclosure

Risk Level

Low

Description

The server reveals version information in HTTP response headers.

Observed:

Server: Apache-Coyote/1.1

Exposing server details helps attackers identify the technologies used by the website.

Impact

Attackers may search for known vulnerabilities related to the exposed server version.

Recommendation

Hide or minimize server version information.

Example:

- Disable detailed server banners
- Configure secure server headers

Finding 5 – X-Content-Type-Options Header Missing

Risk Level

Low

Description

The website does not include the `X-Content-Type-Options` header.

Without this protection, browsers may attempt MIME-type sniffing, which can sometimes lead to malicious file execution.

Evidence

OWASP ZAP identified:

- “X-Content-Type-Options Header Missing”

Impact

Attackers may exploit MIME confusion vulnerabilities in certain situations.

Recommendation

Add the following header:

`X-Content-Type-Options: nosniff`

Finding 6 – Session Management Response Identified

Risk Level

Informational

Description

OWASP ZAP detected the presence of a session management token (**JSESSIONID**).

This is normal behavior for many web applications and was recorded for informational purposes.

Impact

No direct vulnerability identified.

Recommendation

- Ensure:
- Secure cookie handling
 - Proper session expiration
 - Use of Secure and HttpOnly attributes

5. Risk Classification Summary

Risk Level	Number of Findings
High	0
Medium	2
Low	3
Informational	1

6. Security Recommendations

The following improvements are recommended:

Immediate Actions

- Implement Content Security Policy (CSP)
- Enable anti-clickjacking protection
- Add missing security headers

Cookie Security

- Enable SameSite protection
- Use Secure and HttpOnly flags

Information Disclosure

- Hide server technology details
- Minimize unnecessary response headers

Security Maintenance

- Perform regular vulnerability assessments
 - Keep frameworks and plugins updated
 - Conduct periodic security reviews
-

7. Conclusion

The passive vulnerability assessment identified several common web security misconfigurations within the target application.

Although no critical vulnerabilities were discovered, the identified issues may increase the website's exposure to browser-based attacks, information disclosure, and session-related risks.

By implementing proper security headers, improving cookie configurations, and following secure development practices, the overall security posture of the application can be significantly improved.

This assessment was performed ethically within a read-only scope and without exploiting the target system.

8. Evidence Screenshots

Screenshot 1

OWASP ZAP Dashboard showing detected alerts.

Screenshot 2

Content Security Policy (CSP) Header Not Set finding.

Screenshot 3

Missing Anti-clickjacking Header finding.

Screenshot 4

Cookie without SameSite Attribute finding.

Screenshot 5

HTTP response headers showing:

- Server disclosure
 - JSESSIONID cookie
 - Missing security protections.
-

9. Disclaimer

This assessment was conducted strictly for educational and ethical purposes under passive testing scope guidelines.

No exploitation, harmful actions, or unauthorized access attempts were performed during the assessment.